

Relatório de Análise de Vulnerabilidades (DAST) — v3

Tech Challenge — Sistema Integrado da Oficina Mecânica
27/06/2026 (3ª execução — atualização das versões de 21/06 e 26/06/2026)

Relatório de Análise de Vulnerabilidades

1. Metodologia

Item	Detalhe
Ferramenta	OWASP ZAP (<code>zap-api-scan.py</code>), via Docker
Tipo de análise	DAST (Dynamic Application Security Testing)
Alvo	API REST da Oficina Mecânica (NestJS)
Ambiente	Local, via Docker Compose
Escopo (v1)	55 URLs
Escopo (v2)	90 URLs
Escopo (v3)	99 URLs
Autenticação	Token JWT injetado via header <code>Authorization</code> em todas as requisições
Comando utilizado	<code>zap-api-scan.py -t http://localhost:3000/docs-json -f openapi</code>

Este relatório consolida a terceira execução do scan, após duas rodadas de correções aplicadas ao código com base nos relatórios anteriores (21/06 e 26/06/2026).

2. Resumo Executivo

Métrica	v1 (21/06)	v2 (26/06)	v3 (27/06)
URLs escaneadas	55	90	99
Falhas críticas (<code>FAIL-NEW</code>)	0	0	0
Alertas (<code>WARN-NEW</code>)	10	8	5

A terceira rodada confirma uma tendência consistente de melhoria: o número de alertas caiu de 10 para 5 ao longo das três execuções, e nenhuma vulnerabilidade crítica (SQL Injection, XSS, RCE, XXE, Path Traversal, entre outras) foi confirmada em nenhuma das três rodadas.

Itens corrigidos desde a v2:

- Erro 500 em `/servico/:id` com entrada não numérica — corrigido.
- Erro 500 em `/pecas/:id` e `/insumos/:id` por overflow numérico — corrigido.
- Alerta de SQL Injection em `POST /veiculos` — não reapareceu; classificado como falso positivo, confirmado pela ausência total de alertas de SQL Injection nas 1.324 requisições enviadas pela regra `SqlInjectionScanRule` nesta rodada.

Itens novos identificados na v3:

- Erro 500 em `/usuarios/:id` por overflow numérico — mesmo padrão já corrigido em outros controllers, ainda não replicado neste.
- Erro 500 em `GET /ordens-servico` ao receber uma URL como valor do parâmetro de query `status`.

Itens que persistem desde a v1/v2 (sem alteração):

- `CSP: Wildcard Directive`
- `Permissions-Policy Header Not Set`
- `Cross-Origin-Embedder-Policy Header Missing`

3. Achados Detalhados

3.1 Erro 500 em `/usuarios/:id` por overflow numérico

Categoria OWASP: A04 — Insecure Design **Severidade:** Alta

Endpoint afetado: `GET /usuarios/:id` **Status:** Novo achado (mesmo padrão já corrigido em Peças, Insumos e Serviço)

Descrição: ao receber um número válido porém fora do intervalo suportado pelo tipo de dado utilizado (ex: `2803009098818438580`), a API retorna `500 Internal Server Error` em vez de `400 Bad Request`.

Recomendação: aplicar a mesma validação de range numérico já utilizada nos demais controllers (`PecasController`, `InsumosController`, `ServicoController`) ao `UsuarioController`. Reforça-se a recomendação de centralizar essa validação em um Pipe customizado reutilizável, evitando que o mesmo padrão de falha precise ser corrigido individualmente em cada controller.

3.2 Erro 500 em `/ordens-servico` por validação ausente em parâmetro de query

Categoria OWASP: A04 — Insecure Design **Severidade:** Alta

Endpoint afetado: `GET /ordens-servico?status=...` **Status:** Novo achado

Descrição: o parâmetro de query `status`, utilizado para filtrar ordens de serviço, não valida o valor recebido. Ao enviar uma URL como valor (`status=http://www.google.com/`), a API retorna `500 Internal Server Error`.

Risco: diferente dos achados anteriores (que envolviam parâmetros de rota), este ocorre em um parâmetro de query, indicando que a falta de validação de entrada não está isolada a `:id` — também afeta filtros e demais parâmetros opcionais da API.

Recomendação: validar o parâmetro `status` contra os valores permitidos do enum de status da Ordem de Serviço (Recebida, Em diagnóstico, Aguardando aprovação, Em execução, Finalizada, Entrega), retornando `400 Bad Request` para valores fora desse conjunto.

3.3 Headers de segurança — itens ainda pendentes

Categoria OWASP: A05 — Security Misconfiguration **Severidade:** Baixa **Status:** Sem alteração desde a v2

Header / Alerta	Detalhe
CSP: Wildcard Directive	a diretiva de CSP configurada ainda contém wildcard (*), reduzindo a efetividade da proteção
Permissions-Policy Header Not Set	ainda não configurado
Cross-Origin-Embedder-Policy Header Missing	ainda não configurado

Recomendação: ajustar a configuração do `helmet()` para remover wildcards da diretiva de CSP e habilitar explicitamente `Permissions-Policy` e `Cross-Origin-Embedder-Policy`.

3.4 Itens confirmadamente corrigidos (não requerem nova ação)

Achado original	Onde apareceu	Confirmado corrigido em
500 com string inválida em <code>:id</code>	Peças, Insumos	v2
500 com string inválida em <code>:id</code>	Serviço	v3
500 por overflow numérico em <code>:id</code>	Peças, Insumos	v3
Alerta de SQL Injection	POST <code>/veiculos</code>	v3 (não reapareceu)
Headers básicos ausentes (<code>X-Content-Type-Options</code> , <code>X-Powered-By</code> , Anti-clickjacking, CSP básico)	Global	v2

4. Síntese e Priorização

#	Achado	OWASP	Severidade	Esforço	Status
1	Validação de range numérico em <code>/usuarios/:id</code>	A04	Alta	Baixo	Pendente
2	Validação do parâmetro <code>status</code> em <code>/ordens-servico</code>	A04	Alta	Baixo	Pendente
3	Filtro de exceções global (padroniza resposta de erro)	A09	Média	Baixo/Médio	Pendente
4	Refinar CSP (remover wildcard)	A05	Baixa	Baixo	Pendente
5	Habilitar Permissions-Policy e Cross-Origin-Embedder-Policy	A05	Baixa	Baixo	Pendente
6	Validação de ID em <code>Peças/Insumos/Serviço</code> (string e overflow)	A04	—	—	Corrigido
7	SQL Injection em <code>/veiculos</code>	A03	—	—	Corrigido (falso positivo)
8	Headers de segurança básicos (helmet)	A05	—	—	Corrigido

5. Conclusão

A evolução ao longo das três rodadas de teste demonstra um processo de hardening eficaz: o número de alertas caiu de 10 para 5, e os achados de maior severidade identificados inicialmente (validação de entrada em parâmetros de rota, ausência de headers de segurança) foram sistematicamente corrigidos.

O padrão recorrente de falha — ausência de validação robusta de entrada, agora também identificado em um parâmetro de query (`status`) e não apenas em parâmetros de rota (`:id`) — reforça a recomendação já feita nos relatórios anteriores: adotar uma estratégia centralizada de validação (DTOs com `class-validator` para query params, Pipes customizados para parâmetros de rota) em vez de correções pontuais por controller, prevenindo a recorrência deste mesmo tipo de achado em futuras execuções do scan.

Os itens restantes (validação em Usuários e Ordens de Serviço, refinamento de CSP, headers de isolamento de origem) são de baixo esforço de correção e podem ser divididos entre os membros do grupo antes da entrega final.